Guia de Estudo: Comandos Cisco SPAN (Port Mirroring)

Disciplina: Computação Forense / Redes

1. Conceitos Básicos e Sintaxe

- **Sessão:** Um número identificador (ex: 1). Deve ser igual na origem e no destino.
- **RX:** Tráfego de Entrada (Receive).
- **TX:** Tráfego de Saída (Transmit).
- **BOTH:** Ambos (Padrão, se nada for escrito).

---

2. Cenários de Origem Simples

Exercício 1: Espelhamento Básico (Bidirecional)

Pergunta: Espelhar todo o tráfego (entrada e saída) da porta Fa0/1 para a porta Fa0/10.

Solução:

monitor session 1 source interface FastEthernet0/1

monitor session 1 destination interface FastEthernet0/10

Exercício 2: Apenas Tráfego de Entrada (RX)

Pergunta: Espelhar apenas o tráfego recebido (entrada) na porta Gi0/5 para a porta Gi0/20.

Solução:

monitor session 1 source interface GigabitEthernet0/5 rx

monitor session 1 destination interface GigabitEthernet0/20

Exercício 3: Apenas Tráfego de Saída (TX)

Pergunta: Espelhar apenas o tráfego enviado (saída) pela porta Gi0/5 para a porta Gi0/20.

Solução:

monitor session 1 source interface GigabitEthernet0/5 tx

monitor session 1 destination interface GigabitEthernet0/20

---

3. Cenários com Múltiplas Origens

Exercício 4: Múltiplas Portas Específicas (Entrada)

Pergunta: Monitorizar o tráfego de entrada das portas Gi0/23 e Gi0/24 para a porta Gi0/1.

Solução:

monitor session 1 source interface GigabitEthernet0/23 , GigabitEthernet0/24 rx

monitor session 1 destination interface GigabitEthernet0/1

Exercício 5: Múltiplas Portas Específicas (Saída) — *[NOVO]*

Pergunta: Monitorizar o tráfego de saída das portas Gi0/23 e Gi0/24 para a porta Gi0/1.

Solução:

monitor session 1 source interface GigabitEthernet0/23 , GigabitEthernet0/24 tx

monitor session 1 destination interface GigabitEthernet0/1

Exercício 6: Intervalo de Portas (Range)

Pergunta: Monitorizar a entrada (RX) de todas as portas entre a Fa0/1 e a Fa0/5 para a porta Gi0/1.

Solução:

monitor session 1 source interface FastEthernet0/1 - 5 rx

monitor session 1 destination interface GigabitEthernet0/1

---

4. Cenários com VLANs

Exercício 7: Monitorizar uma VLAN Inteira

Pergunta: Espelhar todo o tráfego da VLAN 10 (entrada) para a porta Gi1/2.

Solução:

monitor session 1 source vlan 10 rx

monitor session 1 destination interface GigabitEthernet1/2

Exercício 8: Filtrar Tráfego num Trunk (Avançado)

Pergunta: Monitorizar a porta Gi0/48 (Trunk), mas capturar **apenas** o tráfego da VLAN 99, enviando para a Gi0/10.

Solução:

monitor session 1 source interface GigabitEthernet0/48

monitor session 1 filter vlan 99

monitor session 1 destination interface GigabitEthernet0/10

---

5. Cenários Complexos e "Rasteiras"

Exercício 9: Separação de Tráfego (Entrada vs Saída)

Pergunta: Enviar o tráfego de **entrada** da VLAN 10 para a porta Fa0/10 e o tráfego de **saída** da VLAN 10 para a porta Fa0/11.

Solução:

monitor session 1 source vlan 10 rx

monitor session 1 destination interface FastEthernet0/10

monitor session 2 source vlan 10 tx

monitor session 2 destination interface FastEthernet0/11

Exercício 10: Uma Origem para Múltiplos Destinos (Método Seguro)

Pergunta: Enviar o tráfego da Fa0/2 para duas portas de destino diferentes: Fa0/11 e Fa0/12.

Solução:

monitor session 1 source interface FastEthernet0/2

monitor session 1 destination interface FastEthernet0/11

monitor session 2 source interface FastEthernet0/2

monitor session 2 destination interface FastEthernet0/12

Exercício 11: RSPAN (Remote SPAN - Entre Switches)

Pergunta: Configurar o switch de origem para enviar tráfego da Fa0/1 para uma VLAN remota 900.

Solução:

configure terminal

vlan 900

remote-span

exit

monitor session 1 source interface FastEthernet0/1

monitor session 1 destination remote vlan 900

Exercício 12: Destino com Acesso à Rede (Ingress)

Pergunta: Espelhar Gi0/1 para Gi0/2, permitindo que o computador na Gi0/2 continue a comunicar na rede (VLAN 1).

Solução:

monitor session 1 source interface GigabitEthernet0/1

monitor session 1 destination interface GigabitEthernet0/2 ingress vlan 1

---

6. Comandos de Verificação e Manutenção

Exercício 13: Verificar Configuração

Pergunta: Qual o comando para ver as sessões ativas?

Solução:

show monitor

Exercício 14: Apagar Configuração

Pergunta: Qual o comando para remover a sessão 1?

Solução:

configure terminal

no monitor session 1

Exercício 15: Interpretação de Output

Pergunta: Se o output diz "Source: Fa0/1 (Both)" e "Dest: Fa0/10", qual foi o comando?

Solução:

monitor session 1 source interface FastEthernet0/1 both

monitor session 1 destination interface FastEthernet0/10

GUIA PRÁTICO: SINTAXE E EXERCÍCIOS (TCPDUMP)

1. A FÓRMULA DO COMANDO

Para qualquer exercício, a estrutura inicial é sempre esta:

tcpdump -n -r captura.pcap 'FILTRO'

- **-n**: Mostra IPs em vez de nomes.
- **-r**: Lê o ficheiro pcap.
- **'...'**: O filtro fica sempre dentro de aspas simples.

---

2. VOCABULÁRIO DO FILTRO (BPF)

Usa estas palavras-chave para construir a frase lógica dentro das aspas:

A. Quem? (Direção)

- src host [IP] → **Origem** (Quem enviou).
- dst host [IP] → **Destino** (Quem recebeu).
- host [IP] → **Qualquer** (Envolvendo este IP, seja a enviar ou receber).

B. O Quê? (Protocolo)

- tcp → Maioria dos serviços (Web, Email, FTP, SSH, RDP).
- udp → Infraestrutura (DNS, DHCP, TFTP, SNMP).
- icmp → Ping.
- port [NÚMERO] → Filtra por porta específica.

C. Lógica (Conectores)

- and → **E** (Adiciona condições obrigatórias).
- or → **OU** (Alternativas).
- not → **NÃO** (Exclusão).
- (...) → **Parênteses** (Obrigatórios ao misturar and com or).

---

3. BANCO DE EXERCÍCIOS (Do Básico ao Avançado)

Aqui tens os cenários prontos para aplicar o conhecimento do teu documento:

🟢 **Nível 1: O Básico (Web e Gestão)**

Exercício 1: Acesso Web Seguro (HTTPS)

Cenário: Listar acessos seguros ao servidor Web 192.168.0.1.

Resposta:

tcpdump -n -r captura.pcap 'tcp and dst host 192.168.0.1 and port 443'

Exercício 2: Excluir tráfego inseguro (Telnet)

Cenário: Ver todo o tráfego para o servidor 10.0.0.5, **exceto** Telnet.

Resposta:

tcpdump -n -r captura.pcap 'dst host 10.0.0.5 and not port 23'

🟠 **Nível 2: Os "Combos" (Email e FTP)**

Exercício 3: O "Super Filtro" de Email

Cenário: Listar **todo** o tráfego de email (envio, receção, leitura, seguro ou não) do PC 172.20.20.15.

Resposta:

tcpdump -n -r captura.pcap 'host 172.20.20.15 and (port 25 or port 465 or port 587 or port 110 or port 995 or port 143 or port 993)'

(Nota: Usa parênteses porque estamos a usar host ... and (...))

Exercício 4: FTP (Apenas Login/Comandos)

Cenário: Listar apenas a ligação de controlo FTP para o servidor 192.168.1.10 (ignorar transferência de dados).

Resposta:

tcpdump -n -r captura.pcap 'tcp and dst host 192.168.1.10 and port 21'

🎯 Nível 3: As "Rasteiras" (UDP e Novos Protocolos)

Exercício 5: Configuração Automática e Transferência Simples (UDP)

Cenário: Listar tráfego de DHCP ou TFTP na rede.

Resposta:

tcpdump -n -r captura.pcap 'udp and (port 67 or port 68 or port 69)'

(Atenção: Ambos são UDP. TFTP é porta 69)

Exercício 6: Windows Remote & DNS Seguro

Cenário: Listar acessos RDP (Remote Desktop) ou DNS sobre TLS (DoT) vindos do IP 10.0.0.50.

Resposta:

tcpdump -n -r captura.pcap 'tcp and src host 10.0.0.50 and (port 3389 or port 853)'

(Atenção: RDP é 3389 e DoT é 853. Ambos TCP).

Exercício 7: Monitorização de Rede (SNMP)

Cenário: Listar alertas e consultas SNMP destinadas ao servidor de gestão.

Resposta:

tcpdump -n -r captura.pcap 'udp and dst host [IP_SRV] and (port 161 or port 162)'

💡 RESUMO DA LÓGICA DE PENSAMENTO

No exame, segue estes 3 passos para qualquer pergunta:

1. **Escreve a base:** tcpdump -n -r captura.pcap
2. **Identifica o Protocolo (TCP ou UDP?):** Se for TFTP, DHCP ou DNS normal, começa com udp. O resto é quase tudo tcp.
3. **Monta a frase:** 'src/dst host [IP] and (port X or port Y)'

(Se misturares condições, mete sempre parênteses na parte do or)

🕵️ GUIA MESTRE DE ANÁLISE FORENSE (Hexdump)

1. Regras de Ouro (Antes de tudo!)

A. Endianness (Como ler os bytes?)

A primeira pergunta que fazes é: **"Isto é um Disco ou um Ficheiro?"**

- **DISCO / PARTIÇÃO (MBR, GPT, EXT, FAT):** Usa **Little Endian**.
    - *Regra:* Lê da direita para a esquerda (inverte os bytes).
    - *Vês:* 01 00 $\rightarrow$ *Lês:* 00 01 (1).
    - *Vês:* 00 00 04 00 $\rightarrow$ *Lês:* 00 04 00 00 (262.144).
- **IMAGEM / REDE (PNG, JPEG, TCP/IP):** Usa **Big Endian**.
    - *Regra:* Lê normal (da esquerda para a direita).
    - *Vês:* 00 00 01 F4 $\rightarrow$ *Lês:* 00 00 01 F4 (500).

---

2. Algoritmo de Identificação (O Fluxograma)

Segue estes passos por ordem para descobrires o que tens à frente:

1. **Olha para o Offset 0x000 (LBA 0):**
    - Vês a assinatura 89 50 4E 47? $\rightarrow$ É uma imagem **PNG** (Vai para secção 5).
    - Vês EB XX 90 e texto "FAT"/"NTFS"? $\rightarrow$ É um **Setor de Boot** (Vai para passo 2).
2. **Olha para o Offset 0x200 (LBA 1):**
    - Vês a string EFI PART? $\rightarrow$ É um disco **GPT** (Vai para secção 3).
    - Está tudo a Zeros (00) ou lixo? $\rightarrow$ É **MBR** ou sistema direto (Vai para passo 3).
3. **Olha para o Offset 0x400 (LBA 2):**
    - Calcula 0x400 + 0x38 = 0x438. Vês 53 ef?
    - **SIM:** É uma partição **Linux/EXT** (Vai para secção 4).

---

3. Estruturas de Disco (Tabelas de Consulta)

A. Tabela MBR (Se LBA 1 estiver vazio)

Localização: Offset 0x1BE (dentro da linha 0).

Cada partição tem 16 bytes.

Offset Relativo	O que extrair?	Tamanho	Leitura
+0	Status	1 byte	80 = Bootável
+4	**Tipo de Partição**	1 byte	07=NTFS, 83=Linux, 0C=FAT32
+8	**LBA Inicial**	4 bytes	**Little Endian (Inverte!)**
+12	**Tamanho (Setores)**	4 bytes	**Little Endian (Inverte!)**

B. Tabela GPT (Se LBA 1 tiver "EFI PART")

Localização: Começa no LBA 2 (0x400).

Cada entrada tem 128 bytes.

Offset Relativo	O que extrair?	Tamanho	Leitura
+0	Type GUID	16 bytes	Ignorar
+32 (0x20)	**LBA Inicial**	8 bytes	**Little Endian (Inverte!)**
+40 (0x28)	**LBA Final**	8 bytes	**Little Endian (Inverte!)**

Nota: Tamanho da partição = (LBA Final - LBA Inicial) + 1.

---

4. Estruturas de Sistema de Ficheiros (O conteúdo)

A. Superbloco EXT / Linux

Sinal: Magic Number 53 EF no offset relativo 0x38.

Localização Base: Normalmente 0x400 nos exercícios.

Offset Relativo	O que é?	Exemplo	Valor Decimal
+0	**Total Inodes**	00 00 01 00	Inverte $\rightarrow$ 10000h $\rightarrow$ 65536
+4	**Total Blocos**	00 00 04 00	Inverte $\rightarrow$ 40000h $\rightarrow$ 262144

Offset Relativo	O que é?	Exemplo	Valor Decimal
+56 (0x38)	**Magic Number**	53 EF	Confirma que é EXT2/3/4

B. Boot Sector FAT16/32

Sinal: Texto "FAT16"/"FAT32" nas primeiras linhas.

- **Identificação:** Basta ler o texto ASCII à direita.
- **Label (Nome):** Normalmente offset 0x2B (11 bytes de texto).

---

5. Estrutura de Imagem (PNG)

Atenção: Usa **BIG ENDIAN** (Não inverter!).

Identificação: Assinatura 89 50 4E 47 no início.

Bloco IHDR (Cabeçalho):

Procura os bytes 49 48 44 52 ("IHDR"). Os dados vêm logo a seguir:

1. **Largura (Width):** Primeiros 4 bytes após IHDR.
2. **Altura (Height):** Segundos 4 bytes após IHDR.
3. **Bit Depth:** 1 byte (ex: 08).
4. **Color Type:** 1 byte (ex: 02=RGB, 06=RGB+Alpha).
5. **Compression:** 1 byte (ex: 00=Deflate).

---

6. Exemplo de Conversão Rápida (Hex $\rightarrow$ Dec)

Se tiveres de fazer à mão no exame:

Valor Hex: 2C

- Dígito da esquerda (2) $\times 16$
- Dígito da direita (C que é 12) $\times 1$
- **Conta:** $(2 \times 16) + 12 = 32 + 12 = 44$.

Valor Hex: 100

- $1 \times 16 \times 16 = 256$.

Valores Hex Importantes para Decorar:

- 0x100 = 256
- 0x200 = 512 (Tamanho de 1 setor padrão)
- 0x400 = 1024 (Tamanho de 2 setores)

Dica Final: Se o exercício mostrar "zeros" onde devia estar uma tabela (como no Exercício 8), **não inventes**. Diz: *"A estrutura padrão não existe neste local, mas encontrei a assinatura X no offset Y, o que indica Z."* Isso vale a cotação máxima.

Boa sorte! Com isto estás preparadíssimo.

Grupo I: Princípios e Metodologias (T-01 e T-03)

1. **A investigação forense foca-se na continuidade do negócio, enquanto a recuperação de dados foca na prova pericial.**

Falsa. É ao contrário: Forense foca na prova; Recuperação de dados foca no negócio.

2. **O uso de um bloqueador de escrita (write-blocker) é obrigatório durante a recolha de um dump de memória RAM.**

Falsa. Bloqueadores de escrita são para suportes físicos (discos/pens). Na RAM usa-se software, o que é inerentemente intrusivo.

3. **A "Ordem de Volatilidade" estabelece que os registos da CPU e a RAM devem ser recolhidos antes dos dados em disco.**

Verdadeira. Deve-se recolher primeiro o que desaparece mais depressa.

4. **Uma colisão de hash ocorre quando dois ficheiros diferentes produzem o mesmo valor de resumo.**

Verdadeira. É o que torna algoritmos como MD5 inseguros hoje em dia.

5. **A análise *Live* permite aceder a dados que podem nunca chegar a ser gravados no disco rígido.**

Verdadeira. Ex: Chaves de cifra ou conversas de chat não guardadas.

Grupo II: Estruturas de Dados e Discos (T-02)

6. **No MBR (Master Boot Record), a tabela de partições tem espaço para definir até 8 partições primárias.**

Falsa. O limite são 4 partições primárias.

7. **O GPT (GUID Partition Table) utiliza um "Protective MBR" no início do disco para manter compatibilidade com sistemas antigos.**

Verdadeira. Evita que ferramentas antigas considerem o disco como "vazio".

8. **Ao formatar um disco com "Quick Format", os dados dos clusters são preenchidos com zeros.**

Falsa. Apenas a tabela de índice é limpa; os dados permanecem lá até serem sobrescritos.

9. **O Slack Space (espaço de folga) pode conter fragmentos de ficheiros eliminados anteriormente.**

Verdadeira. Ocorre porque o sistema escreve em clusters fixos e não limpa o resto do espaço se o ficheiro for menor.

10. **Em sistemas NTFS, os metadados do sistema de ficheiros (como a data de criação) são armazenados na MFT.**

Verdadeira. A Master File Table guarda os atributos de cada ficheiro.

Grupo III: Forense Mobile e Apps (T-04 e T-05)

11. **Uma aquisição "Física" de um smartphone permite recuperar mensagens eliminadas da base de dados SQLite.**

Verdadeira. Como copia bit-a-bit, traz os registos marcados como eliminados mas ainda não sobrescritos.

12. **O número IMSI identifica de forma única o aparelho (hardware) do telemóvel.**

Falsa. O IMSI identifica o cartão SIM/subscritor. O IMEI identifica o hardware.

13. **O AndroidManifest.xml é o ficheiro onde se encontram as permissões que a app solicita ao sistema.**

Verdadeira.

14. **Ficheiros APK são binários compilados que não podem ser abertos como pastas compactadas.**

Falsa. São ficheiros ZIP e podem ser abertos com qualquer descompactador.

15. **O isolamento de rede (Saco de Faraday) é dispensável se o telemóvel estiver protegido por código PIN.**

Falsa. É essencial para evitar o *Remote Wipe* (limpeza remota) via rede.

Grupo IV: Forense de Redes (T-06)

16. **O tráfego de rede é considerado uma evidência não volátil.**

Falsa. É extremamente volátil; se não for capturado no momento, perde-se.

17. **O NetFlow é uma técnica que permite reconstruir o conteúdo exato (payload) de um e-mail enviado.**

Falsa. O NetFlow guarda apenas estatísticas (quem falou com quem, quando e quanto), não o conteúdo.

18. **A sintaxe tcp.port == 443 é um exemplo de um filtro de captura BPF (Berkeley Packet Filter).**

Falsa. Esta é a sintaxe de um filtro de visualização do Wireshark. Um BPF seria apenas port 443.

19. **O utilitário tshark permite realizar capturas de rede através da linha de comandos.**

Verdadeira. É a versão CLI do Wireshark.

20. **O endereço MAC é utilizado para encaminhar pacotes entre redes diferentes através da Internet.**

Falsa. O endereço MAC é para a rede local (Layer 2). Entre redes usa-se o endereço IP (Layer 3).

Grupo V: Ferramentas Específicas

21. **No Volatility, o plugin pslist é o mais eficaz para detetar processos escondidos por Rootkits.**

Falsa. O pslist segue a lista oficial do Windows. Para detetar processos escondidos usa-se o psxview.

22. **O Autopsy é uma ferramenta que pode ser usada tanto para análise de discos como para análise de aquisições móveis.**

    Verdadeira.

23. **A ferramenta JADX permite transformar código Dalvik (.dex) de volta em código Java legível.**

    Verdadeira.

24. **O Wireshark consegue descifrar tráfego HTTPS nativamente sem necessidade de chaves privadas.**

Falsa. Sem a chave privada ou as chaves de sessão, o conteúdo permanece cifrado.

25. **O comando file no Linux baseia-se na extensão do ficheiro para indicar o seu tipo.**

Falsa. Baseia-se nos "Magic Numbers" (assinaturas no cabeçalho do ficheiro).

Respostas ao Grupo I - Pergunta 1

a) Uma evidência digital pode refutar um acontecimento.

Verdadeira. A evidência digital é definida como um objeto digital que contém informação fidedigna que suporte ou **refute** uma hipótese.

b) É sempre possível recuperar ficheiros eliminados.

Falsa. Embora existam técnicas como *file carving* para recuperar dados , a recuperação depende de os dados não terem sido **sobrescritos**.

c) A análise *Live* é uma evolução da análise tradicional.

Falsa. O material indica que a investigação *live* deve ser vista como uma **técnica complementar** e não como uma substituta da análise tradicional (post-mortem).

d) O Autopsy permite a utilização de *hashsets* do NSRL.

Verdadeira. (Nota: Embora o slide cite o Autopsy para análise de dispositivos móveis, é uma funcionalidade padrão da ferramenta permitir o uso de bases de dados de hashes conhecidas como o NSRL para filtrar ficheiros irrelevantes).

e) Funções de resumo permitem garantir a integridade de dados.

Verdadeira. As funções de resumo (hash) permitem a deteção de qualquer alteração nos dados originais, pois dois conjuntos de dados diferentes devem gerar resumos diferentes.

f) Tráfego de rede só pode ser capturado em tempo-real.

Verdadeira. Esta é uma das características intrínsecas da análise de redes: a **temporalidade**, significando que o tráfego deve ser capturado no momento em que ocorre.